



METODOLOGÍA DE GESTIÓN DE RIESGOS DE SEGURIDAD DE LA INFORMACIÓN

PEARTREES MEDICAL SERVICES

Miguel Perales Rubio
[Dirección de correo electrónico]

CONTROL DEL DOCUMENTO	
Campo	Información
Nombre del documento	Metodología de Gestión de Riesgos de Seguridad de la Información
Código	GRC-RM-001
Versión	1.0
Propietario	Responsable del SGSI
Aprobador	Dirección
Clasificación	Uso interno
Fecha de emisión	Septiembre 2026
Fecha de revisión	Septiembre 2027
Estado	Aprobado
Norma de referencia	ISO/IEC 27001:2022

AVISO DE PROPIEDAD INTELECTUAL Y DERECHOS DE USO

© 2026 Miguel Perales. Todos los derechos reservados.

Este documento ha sido elaborado como parte de un portfolio profesional orientado a la gestión de riesgos, gobierno, riesgo y cumplimiento (GRC) y seguridad de la información.

La organización *PearTrees Medical Services* utilizada en este documento es ficticia y se emplea exclusivamente con fines académicos, formativos y demostrativos. Los escenarios, activos, procesos, responsables, registros y demás elementos asociados a dicha organización no representan información real de una entidad existente.

El contenido del documento, incluyendo su estructura, redacción, análisis, modelos y elementos desarrollados específicamente para este portfolio, es obra de su autor.

Se permite la consulta y visualización del documento con fines personales, educativos o profesionales, siempre que se mantenga la atribución correspondiente.

No se autoriza, sin consentimiento previo del autor:

- La reproducción íntegra del documento con finalidad comercial.
- La redistribución del documento como obra propia.
- La modificación y publicación del documento atribuyéndolo a terceros.
- La utilización del contenido para elaborar productos o servicios comerciales basados sustancialmente en este trabajo.

Las referencias a normas, estándares, metodologías o marcos profesionales pertenecen a sus respectivos propietarios y se utilizan únicamente como referencias dentro del trabajo.

La inclusión de este documento en el portfolio no implica certificación, acreditación ni conformidad formal con ninguna norma o estándar. El documento constituye un ejercicio profesional simulado y no sustituye una auditoría, evaluación de conformidad o certificación realizada por un organismo competente.

Contenido

I.	Introducción	5
II.	Objetivo.....	5
III.	Alcance	5
IV.	Principios de la metodología	6
	4.1 Enfoque basado en riesgos	6
	4.2 Confidencialidad, integridad y disponibilidad	6
	4.3 Proporcionalidad.....	6
	4.4 Trazabilidad	7
	4.5 Revisión continua.....	7
V.	Proceso de gestión de riesgos	7
	5.1 Identificación.....	7
	5.2 Análisis.....	7
	5.3 Valoración	7
	5.4 Tratamiento	7
	5.5 Riesgo residual.....	7
	5.6 Seguimiento.....	8
VI.	Identificación de riesgos	8
	6.1 Activo	8
	6.2 Amenaza	8
	6.3 Vulnerabilidad.....	8
	6.4 Consecuencia.....	9
VII.	Valoración del riesgo	9
	7.1 Probabilidad	9
	7.2 Impacto	10
	7.3 Matriz de riesgos	10
VIII.	Criterios de aceptación	10
IX.	Tratamiento del riesgo	11
	9.1 Reducir.....	11
	9.2 Evitar.....	11
	9.3 Transferir o compartir	11

9.4 Aceptar.....	11
X. Riesgo residual.....	12
XI. Seguimiento y revisión	12
XII. Registros y evidencias	13
XIII. Mejora continua	13
ANEXO I: EJEMPLO DE REGISTRO DE RIESGO.....	14
ANEXO II: RELACIÓN CON LA DOCUMENTACIÓN DEL SGSI	14
FIN DEL DOCUMENTO	15

I. Introducción

La gestión de riesgos constituye uno de los elementos fundamentales del Sistema de Gestión de Seguridad de la Información (SGSI) de PearTrees Medical Services.

La organización depende, en gran medida, de sistemas de información para el desarrollo de sus actividades asistenciales, administrativas y de gestión. Una posible indisponibilidad, alteración, pérdida o divulgación no autorizada de información podría afectar a la continuidad de los servicios y generar consecuencias operativas, legales y reputacionales.

Esta metodología establece un procedimiento común para identificar, analizar, valorar y tratar los riesgos relacionados con la seguridad de la información.

II. Objetivo

El objetivo de esta metodología es establecer un criterio homogéneo para:

- Identificar activos y procesos relevantes.
- Identificar amenazas y vulnerabilidades.
- Analizar los riesgos de seguridad de la información.
- Determinar el nivel de riesgo inherente.
- Identificar los controles existentes.
- Determinar el riesgo residual.
- Definir medidas de tratamiento.
- Facilitar la aceptación, seguimiento y revisión de los riesgos.

La metodología pretende proporcionar información objetiva para apoyar la toma de decisiones sobre seguridad de la información.

III. Alcance

Esta metodología se aplica a los activos, procesos, sistemas, información, personas y servicios incluidos dentro del alcance del SGSI de PearTrees Medical Services.

Se consideran especialmente relevantes:

- Sistemas de historia clínica electrónica.

- Sistemas de laboratorio e imagen.
- Infraestructura de red.
- Sistemas de autenticación y directorio.
- Servicios VPN y acceso remoto.
- Sistemas de almacenamiento y bases de datos.
- Sistemas de seguridad perimetral y protección de endpoints.
- Copias de seguridad.
- Información de pacientes y empleados.
- Servicios proporcionados por terceros.
- Procesos críticos para la continuidad de la organización.

La valoración podrá realizarse tanto sobre activos individuales como sobre procesos o servicios cuando resulte más adecuado.

IV. Principios de la metodología

La gestión de riesgos se basa en los siguientes principios:

4.1 Enfoque basado en riesgos

Los recursos de seguridad se priorizarán en función del nivel de riesgo identificado.

4.2 Confidencialidad, integridad y disponibilidad

La valoración tendrá en cuenta el posible impacto sobre:

- **Confidencialidad:** acceso o divulgación no autorizada.
- **Integridad:** modificación, destrucción o alteración no autorizada.
- **Disponibilidad:** interrupción o pérdida de acceso a la información o sistemas.

4.3 Proporcionalidad

Las medidas de tratamiento deberán ser proporcionales al nivel de riesgo y a la importancia del activo o proceso afectado.

4.4 Trazabilidad

Las decisiones relacionadas con los riesgos deberán quedar registradas y poder relacionarse con los controles y evidencias correspondientes.

4.5 Revisión continua

Los riesgos no se consideran estáticos. Deberán revisarse cuando se produzcan cambios relevantes en los sistemas, procesos, amenazas, proveedores o requisitos aplicables.

V. Proceso de gestión de riesgos

La gestión de riesgos seguirá las siguientes etapas:

1. Identificación → 2. Análisis → 3. Valoración → 4. Tratamiento → 5. Riesgo residual → 6. Seguimiento

5.1 Identificación

Se identifican los activos, procesos o servicios que puedan estar expuestos a situaciones que afecten a la seguridad de la información.

5.2 Análisis

Para cada riesgo se identifican:

- Activo o proceso afectado.
- Amenaza.
- Vulnerabilidad o condición que facilita el riesgo.
- Consecuencias potenciales.
- Controles existentes.

5.3 Valoración

Se determina la probabilidad y el impacto para obtener el nivel de riesgo inherente.

5.4 Tratamiento

Cuando el nivel de riesgo lo requiera, se establece una medida de tratamiento.

5.5 Riesgo residual

Después de considerar los controles existentes y las medidas previstas, se determina el riesgo residual.

5.6 Seguimiento

Los riesgos y las acciones asociadas se revisan periódicamente.

VI. Identificación de riesgos

Cada riesgo deberá describirse siguiendo una estructura homogénea.

6.1 Activo

Elemento que posee valor para la organización.

Ejemplos:

- Historia clínica electrónica.
- Base de datos PostgreSQL.
- Servidor.
- Equipamiento de red.
- Información de pacientes.
- Sistema de copias de seguridad.

6.2 Amenaza

Evento o circunstancia que puede provocar un impacto negativo sobre el activo.

Ejemplos:

- Ransomware.
- Phishing.
- Malware.
- Acceso no autorizado.
- Fallo de hardware.
- Error humano.
- Pérdida de conectividad.

6.3 Vulnerabilidad

Debilidad o condición que puede facilitar la materialización de una amenaza.

Ejemplos:

- Credenciales comprometidas.

- Sistemas sin actualizar.
- Configuración incorrecta.
- Falta de segmentación.
- Dependencia de un único componente.
- Ausencia de controles adecuados.

6.4 Consecuencia

Se describe el efecto que tendría la materialización del riesgo sobre la organización.

Las consecuencias pueden afectar a:

- Operaciones.
- Pacientes.
- Información.
- Cumplimiento legal.
- Continuidad del servicio.
- Economía.
- Reputación.

VII. Valoración del riesgo

El riesgo inherente se calculará mediante:

Riesgo = Probabilidad × Consecuencia

La probabilidad y la consecuencia se valorarán en una escala de 1 a 5.

7.1 Probabilidad

Valor	Nivel	Criterio
1	Muy baja	Materialización poco probable
2	Baja	Puede producirse ocasionalmente
3	Media	Puede producirse con cierta frecuencia
4	Alta	Probable materialización
5	Muy alta	Muy probable o frecuente

7.2 Consecuencia o Impacto

Valor	Nivel	Criterio
1	Mínima	Consecuencias mínimas
2	Menor	Afectación limitada
3	Moderada	Afectación significativa
4	Mayor	Consecuencias importantes
5	Máxima	Consecuencias graves o críticas

7.3 Matriz de riesgos

Matriz de riesgos						
		Consecuencia				
		Mínima	Menor	Moderada	Mayor	Máxima
Probabilidad		1	2	4	8	16
Muy alta	5	5	10	20	40	80
Alta	4	4	8	16	32	64
Media	3	3	6	12	24	48
Baja	2	2	4	8	16	32
Muy baja	1	1	2	4	8	16

Nivel de riesgo	Color	Valores
Riesgo aceptable		≤ 4
Riesgo tolerable		≥ 5 y ≤ 12
Riesgo alto		≥ 16 y ≤ 24
Riesgo extremo		≥ 32

VIII. Criterios de aceptación

8. CRITERIOS DE ACEPTACIÓN

Los niveles de riesgo se utilizarán para determinar la respuesta necesaria.

Nivel	Criterio general
Bajo	Puede aceptarse manteniendo los controles existentes y realizando seguimiento
Medio	Debe analizarse la necesidad de medidas adicionales
Alto	Requiere un plan de tratamiento y seguimiento
Crítico	Requiere actuación prioritaria y decisión formal de tratamiento

La aceptación de un riesgo deberá ser realizada por la autoridad responsable definida dentro del SGSI.

La aceptación deberá quedar registrada y, cuando proceda, incluir:

- Riesgo aceptado.
- Justificación.
- Responsable.
- Fecha.
- Periodo de validez.
- Fecha de revisión.

IX. Tratamiento del riesgo

Las opciones de tratamiento consideradas serán:

9.1 Reducir

Aplicar controles destinados a disminuir la probabilidad o el impacto.

Ejemplo:

Implantar MFA para reducir el riesgo de compromiso de cuentas.

9.2 Evitar

Eliminar la actividad, proceso o situación que genera el riesgo cuando sea viable.

9.3 Transferir o compartir

Trasladar parte de las consecuencias o responsabilidades a un tercero mediante mecanismos contractuales, seguros u otros acuerdos.

9.4 Aceptar

Mantener el riesgo cuando se encuentre dentro de los criterios de aceptación establecidos y exista una decisión formal.

La opción seleccionada deberá quedar documentada junto con las acciones necesarias y su responsable.

X. Riesgo residual

El riesgo residual representa el nivel de riesgo que permanece después de considerar los controles existentes y las medidas de tratamiento aplicadas o previstas.

Ejemplo:

Riesgo identificado

Ransomware → indisponibilidad de la historia clínica electrónica.

Riesgo inherente

Probabilidad: 4

Impacto: 5

Riesgo: 20 — Crítico

Controles existentes

- Firewall.
- Protección EDR.
- Copias de seguridad.
- Autenticación reforzada.
- Segmentación de red.
- Monitorización.

Tras evaluar la eficacia de los controles, se determinará el nivel de riesgo residual.

El riesgo residual deberá permanecer dentro del nivel aceptable establecido por la organización o, en caso contrario, requerirá nuevas medidas de tratamiento.

XI. Seguimiento y revisión

El registro de riesgos deberá revisarse:

- Como mínimo una vez al año.
- Cuando se produzcan cambios importantes en los sistemas.
- Ante nuevos servicios o procesos.
- Cuando aparezcan nuevas amenazas relevantes.
- Después de incidentes de seguridad significativos.

- Ante cambios legales o regulatorios relevantes.
- Cuando se detecten deficiencias en los controles.

La revisión deberá comprobar, como mínimo:

- Vigencia del riesgo.
- Nivel de riesgo.
- Eficacia de los controles.
- Estado de las acciones.
- Nivel de riesgo residual.
- Necesidad de nuevas medidas.

XII. Registros y evidencias

La aplicación de esta metodología generará, como mínimo, los siguientes registros:

Registro	Finalidad
Registro de riesgos	Identificar y valorar los riesgos
Plan de tratamiento	Gestionar las medidas necesarias
Registro de aceptación	Documentar riesgos aceptados
Evidencias de controles	Demostrar la aplicación de medidas
Revisiones de riesgos	Mantener actualizado el análisis
Registro de acciones	Controlar las medidas pendientes

Estos registros formarán parte de la documentación del SGSI y deberán mantenerse bajo los criterios de control documental establecidos en la Política de Seguridad de la Información.

XIII. Mejora continua

Los resultados de la gestión de riesgos se utilizarán para mejorar progresivamente el SGSI.

Las conclusiones obtenidas de:

- Incidentes.
- Auditorías.
- Revisiones.

- Cambios tecnológicos.
- Nuevas amenazas.
- Resultados de indicadores.
- No conformidades.
- Acciones correctivas.

podrán generar nuevas valoraciones de riesgo o modificaciones en los tratamientos existentes.

La gestión de riesgos deberá mantenerse alineada con los objetivos de seguridad y con el principio de mejora continua establecido por el SGSI.

ANEXO I: EJEMPLO DE REGISTRO DE RIESGO

Campo	Ejemplo
ID	R-001
Activo	Historia clínica electrónica
Proceso	Atención sanitaria
Amenaza	Ransomware
Vulnerabilidad	Compromiso de credenciales / endpoint
Riesgo	Indisponibilidad de la historia clínica
Probabilidad	4
Impacto	5
Riesgo inherente	20 [Alto]
Controles existentes	EDR, firewall, copias, MFA, monitorización
Tratamiento	Reducir
Responsable	Responsable del SGSI / IT
Riesgo residual	Pendiente de valoración
Estado	Abierto

ANEXO II: RELACIÓN CON LA DOCUMENTACIÓN DEL SGSI

Esta metodología se relaciona principalmente con:

- Política de Seguridad de la Información.
- Registro de riesgos.
- Plan de tratamiento de riesgos.
- Declaración de Aplicabilidad (SOA).

- Matriz de cumplimiento.
- Registro de evidencias.
- Procedimientos de gestión de incidentes.
- Documentación de continuidad.
- Registro de acciones correctivas.
- Documentación de auditoría interna.

La relación entre riesgos, controles, requisitos, evidencias y acciones se desarrollará progresivamente mediante las matrices y registros correspondientes del SGSI.

FIN DEL DOCUMENTO

GRC-RM-001 — Metodología de Gestión de Riesgos de Seguridad de la Información

Versión 1.0 — Septiembre 2026